

Business Requirements Document

SecureBank — Banking Management System with AI Loan Assistant

Version: 2.0

Date: June 15, 2026

Status: Final

HOW TO USE THIS DOCUMENT (AI Skill Instructions)

This document is the authoritative source of business rules for the SecureBank system. When answering questions or generating code, policies, or workflows related to SecureBank:

- Treat every requirement in Section 5 as a hard rule unless a later section explicitly overrides it.
- Treat the permission matrix in Section 7 as the single source of truth for what each role may or may not do.
- Transfer limits in FR-TXN-2 and FR-TXN-3 are non-negotiable business rules — never generate logic that bypasses them.
- Use the Glossary (Section 10) to resolve any ambiguity in terminology.
- When in doubt about an authorization decision, default to Deny.

1. Executive Summary

SecureBank is a full-stack banking management web application that digitizes core banking operations — account management, fund transfers, loan lifecycle management, and user administration — under a fine-grained, policy-driven authorization framework. The system integrates an AI-powered Loan Assistant to assist bank staff in reviewing and acting on loan applications using natural language, reducing manual review time and ensuring consistent, policy-compliant decisions.

2. Business Context

2.1 Problem Statement

Traditional banking back-office tools suffer from three recurring problems:

1. **Coarse access control** — role checks are inconsistent across the system, making them brittle and difficult to audit or change without broad code changes.
2. **Manual loan processing** — loan officers must navigate multiple screens, cross-reference customer data, and apply judgment manually, leading to inconsistent decisions and slow turnaround times.
3. **Poor auditability** — authorization decisions are not recorded in a structured, queryable way, making compliance reporting labor-intensive.

2.2 Business Objectives

#	Objective
BO-1	Provide a single web interface for all core banking operations accessible by Account Holders, Bank Tellers, and Bank Managers
BO-2	Enforce consistent, policy-driven authorization across every sensitive action via a centralized Authorization Service
BO-3	Reduce loan review time by providing an AI assistant that can retrieve customer data, evaluate loan eligibility, and produce approval summaries
BO-4	Maintain a complete, structured audit trail of every authorization decision for compliance and forensic purposes
BO-5	Support a maker-checker approval workflow for sensitive account and profile changes
BO-6	Enforce daily transfer limits per role to control financial risk and fraud exposure

3. Scope

3.1 In Scope

- User authentication (session-based login)
- User profile management with pending-change approval workflow
- Bank account management (create, view, edit, delete, full-edit with approval)
- Fund transfers between accounts with role-based and daily limits
- Transaction recording and history
- Full loan lifecycle: apply → review → offer → approve/reject → accept/decline
- AI Loan Assistant (natural language interface)
- Policy-based authorization for all sensitive actions
- Audit log capture, viewing, and statistical reporting
- Role-based UI controls driven by real-time permission checks

3.2 Out of Scope

- Real core banking system integration (payments rails, SWIFT, ACH)
- Customer onboarding / KYC verification workflow execution
- Mobile native applications
- Multi-branch / multi-institution federation
- Report generation / export to PDF or Excel

4. Stakeholders

Role	Description	System Role
Account Holder	Bank customer; can view own accounts, apply for loans, accept/decline loan offers, and initiate transfers within daily limits	Account Holder
Bank Teller	Front-line bank staff; can manage accounts, process transactions, offer/reject loans, initiate transfers above the Account Holder limit with Bank Manager approval, and view audit logs	Bank Teller
Bank Manager	Senior bank staff; all Teller permissions plus approve/reject loans of any amount, approve sensitive account/profile changes, approve high-value transfers, export audit logs, and delete accounts	Bank Manager
System Administrator	Manages authorization policies and environment configuration; does not have a UI role	—

5. Functional Requirements

5.1 Authentication & Session Management

ID	Requirement
FR-AUTH-1	The system shall present a list of available users on the login screen
FR-AUTH-2	A user shall log in by selecting their account; the server shall validate the credentials and create a session
FR-AUTH-3	Sessions shall be maintained via server-side session cookies
FR-AUTH-4	Any unauthenticated request to a protected endpoint shall be rejected with an "Unauthorized" error
FR-AUTH-5	The system shall support explicit logout, destroying the server-side session

5.2 Dashboard

ID	Requirement
----	-------------

FR-DASH-1	Upon login, users shall see an aggregate dashboard showing total customers, total account balance, total loan value, account count, loan count, and recent transactions
FR-DASH-2	Dashboard data shall be scoped to data the authenticated user is permitted to see based on their role

5.3 User Management

ID	Requirement
FR-USER-1	Bank Managers and Tellers shall be able to list, view, create, and update user records
FR-USER-2	Only Bank Managers shall be able to delete user records
FR-USER-3	Sensitive profile field changes shall be submitted as pending changes and require Bank Manager approval before taking effect
FR-USER-4	Bank Managers shall be able to approve or reject pending profile changes with optional notes
FR-USER-5	A user's risk level (Low / Medium / High) shall be updatable and shall influence authorization decisions for that user

5.4 Account Management

ID	Requirement
FR-ACCT-1	Authenticated users shall be able to list and view bank accounts according to their role permissions
FR-ACCT-2	Bank Tellers and Managers shall be able to create new accounts and perform basic updates (balance, status)
FR-ACCT-3	Sensitive field edits (interest rate, credit limit, SSN, credit score, annual income) shall follow a maker-checker workflow requiring Bank Manager approval before changes take effect
FR-ACCT-4	Only Bank Managers shall be able to delete accounts
FR-ACCT-5	Pending account changes shall be viewable and actionable (approve / reject) by Bank Managers
FR-ACCT-6	The system shall gate UI controls for each account action based on the user's real-time authorization status

5.5 Transactions & Transfers

ID	Requirement
FR-TXN-1	The system shall maintain a full transaction history (deposits, withdrawals, transfers, fees)
FR-TXN-2	Account Holders are subject to a \$5,000 daily transfer limit. Any single transfer or cumulative daily transfers by an Account Holder that reach or exceed \$5,000 shall be rejected by the system
FR-TXN-3	Transfers exceeding \$5,000 may only be initiated by a Bank Teller, and require Bank Manager approval before the funds are moved. The system shall not complete such a transfer without explicit Manager approval on record
FR-TXN-4	All fund transfers shall be authorized by the system's Authorization Service before execution; the service evaluates the user's role, risk level, and transfer amount
FR-TXN-5	A list of valid transfer destination accounts shall be available for use in the transfer interface
FR-TXN-6	Bank Managers shall be able to delete transaction records

5.6 Loan Lifecycle

ID	Requirement
FR-LOAN-1	Account Holders shall be able to apply for loans (personal, auto, home, business) by providing type, amount, term, and purpose
FR-LOAN-2	Bank Tellers and Managers shall be able to review pending loan applications and make offer or reject decisions
FR-LOAN-3	Loan approval is subject to the following limits: Bank Tellers may approve loans up to and including \$50,000; Bank Managers may approve loans of any amount. No other role may approve a loan
FR-LOAN-4	Account Holders shall be able to accept or decline a loan that has been offered to them
FR-LOAN-5	Loan status shall follow the defined lifecycle: pending → offered → accepted / rejected → approved / declined → active → paid_off
FR-LOAN-6	The system shall gate UI controls for each loan action based on the user's real-time authorization status

5.7 AI Loan Assistant

ID	Requirement
----	-------------

FR-AI-1	The system shall provide a natural language chat interface that allows bank staff to query loan and customer data and initiate authorized loan actions
FR-AI-2	The AI agent shall complete each request within 45 seconds; requests that exceed this limit shall return a clear timeout message to the user
FR-AI-3	The agent shall have access to the following banking tools: list accounts, get account details, list loans, get loan details, list transactions, get user information, approve loan, prepare approval summary, get transfer information
FR-AI-4	The approve loan and prepare approval summary tools shall be gated by the Authorization Service before the agent may execute them
FR-AI-5	All other agent tools shall be gated by the user's role
FR-AI-6	Agent requests shall require a signed security token in addition to a session credential
FR-AI-7	If the underlying AI service is temporarily unavailable due to capacity limits, the system shall automatically retry up to 3 times using increasing wait periods (10 seconds, 20 seconds, 40 seconds) before surfacing an error to the user
FR-AI-8	The AI agent shall never make its own authorization decisions; it must always delegate approval decisions to the Authorization Service
FR-AI-9	The agent shall be limited to a maximum of 3 tool-call rounds per request to prevent runaway execution

5.8 Authorization

ID	Requirement
FR-AUTHZ-1	All sensitive actions shall be evaluated by the centralized Authorization Service before execution
FR-AUTHZ-2	Authorization decisions shall consider the user's role, risk level, and the specific action and resource being accessed
FR-AUTHZ-3	The frontend shall check authorization status before rendering action controls, ensuring the UI accurately reflects what the user is permitted to do without relying on failed API calls
FR-AUTHZ-4	Every authorization decision — whether Allow or Deny — shall be recorded in the audit log
FR-AUTHZ-5	When the Authorization Service is unavailable, the system shall default to Deny for all gated actions

5.9 Audit Logging

ID	Requirement
FR-AUDIT-1	Every authorization decision shall be captured in a structured audit log entry containing: user, role, action, resource type, resource ID, decision (Allow / Deny), description, and risk level
FR-AUDIT-2	Bank Tellers and Managers shall be able to view the audit log and filter by action, role, and decision
FR-AUDIT-3	Only Bank Managers shall be able to export audit log data
FR-AUDIT-4	An audit statistics summary shall be available showing total requests, allow/deny counts, high-risk action counts, and breakdowns by role and action

6. Non-Functional Requirements

ID	Category	Requirement
NFR-1	Performance	The AI assistant shall respond within 45 seconds under normal service conditions
NFR-2	Performance	All non-AI REST API endpoints shall respond within 500 ms under normal load
NFR-3	Security	All secrets and credentials shall be stored in environment secrets; they shall never appear in source code or logs
NFR-4	Security	AI agent requests shall require a signed token in addition to a session cookie; the server shall verify the token on every request
NFR-5	Security	Session cookies shall be HTTP-only and scoped to the application domain
NFR-6	Availability	The system shall handle temporary AI service unavailability gracefully using automatic retries with backoff, without crashing or returning unhandled errors

NFR-7	Auditability	Every authorization call shall produce a permanent audit record, enabling full reconstruction of who did what and whether it was permitted
NFR-8	Portability	The production build shall start cleanly without loading any development-only dependencies at runtime
NFR-9	Maintainability	Authorization policy changes shall require only changes to the Authorization Service policy configuration, not application code changes

7. Authorization & Permission Matrix

This matrix is the definitive reference for what each role may do. Any system behavior that contradicts this table is a defect.

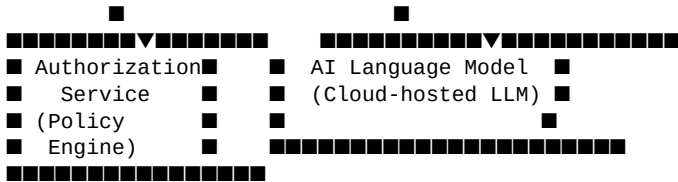
Action	Account Holder	Bank Teller	Bank Manager
View own accounts	■	■	■
View all accounts	■	■	■
View sensitive account fields	■	■	■
Create / update accounts	■	■	■
Delete accounts	■	■	■
Submit sensitive account field changes	■	■ (pending approval)	■ (pending approval)
Approve sensitive account field changes	■	■	■
Transfer funds ≤ \$5,000 per day	■	■	■
Transfer funds > \$5,000	■	■ (requires Manager approval)	■
View transaction history	■ (own)	■ (all)	■ (all)
Delete transaction records	■	■	■
Apply for a loan	■	■	■
Offer / reject a loan	■	■	■
Approve loan ≤ \$50,000	■	■	■
Approve loan > \$50,000	■	■	■

Accept / decline a loan offer	■	■	■
Use AI Loan Assistant	■	■	■
AI: prepare approval summary	■	■	■
AI: approve loan tool	■	■ (≤ \$50k)	■ (any amount)
View audit logs	■	■	■
Export audit logs	■	■	■
Approve profile / account changes	■	■	■
Submit profile changes (own)	■	■	■
Manage user records	■	■ (create / update)	■ (full)
Delete user records	■	■	■

8. Transfer Limit Business Rules (Detailed)

The following rules govern all fund transfer operations and shall be enforced by both the Authorization Service and application logic:

Rule ID	Rule
TR-1	An Account Holder may not initiate a single transfer exceeding \$5,000
TR-2	An Account Holder's cumulative outbound transfers in a calendar day shall not exceed \$5,000
TR-3	A transfer that would cause an Account Holder to exceed the \$5,000 daily cap shall be rejected at the point of submission with a clear message stating the remaining daily allowance
TR-4	A Bank Teller may initiate a transfer of any amount, but transfers exceeding \$5,000 shall be held in a pending state and require explicit Bank Manager approval before funds are moved
TR-5	A Bank Manager may initiate and self-approve transfers of any amount
TR-6	Risk level affects authorization: an Account Holder with a High risk level may have their transfer capability suspended at the discretion of policy; the Authorization Service is the final arbiter



11. Glossary

Term	Definition
Account Holder	A bank customer with access to their own accounts, transfers within limits, and loan applications
Bank Teller	Front-line bank staff with authority over accounts, transactions, and loans up to \$50,000
Bank Manager	Senior bank staff with full authority including high-value loan approval and policy-sensitive actions
Authorization Service	The centralized service that evaluates whether a given user may perform a given action on a given resource
Maker-Checker	A two-step approval workflow where one user submits a change and a second authorized user approves or rejects it
Daily Transfer Limit	The maximum cumulative outbound transfer amount an Account Holder may initiate in a single calendar day (\$5,000)
Loan Approval Limit	The maximum loan amount a role may approve: Bank Teller ≤ \$50,000; Bank Manager — no limit
AI Loan Assistant	The natural language interface that allows bank staff to query data and initiate authorized loan actions using plain English
Audit Log	A permanent, structured record of every authorization decision made by the system
Risk Level	A classification (Low / Medium / High) assigned to a user that influences what the Authorization Service will permit them to do
Pending Change	A proposed modification to a sensitive field that is held for Bank Manager review before being applied
Session	A server-side authentication record created at login and destroyed at logout; all API requests must carry a valid session
Signed Token	A tamper-evident credential required for AI assistant requests, verified server-side on every call
Loan Lifecycle	The sequence of states a loan passes through: pending → offered → accepted/rejected → approved/declined → active → paid_off

